

认证机制漏洞报告（Lab2：密码重置失效逻辑）

1. 漏洞名称

认证逻辑失效（Authentication Logic Flaw） — 密码重置令牌绕过

2. 漏洞等级

高危（High）

3. 漏洞描述

该网站的“忘记密码”功能存在逻辑缺陷。系统虽然生成了随机的密码重置 Token（令牌），但后端在最终执行密码修改操作时，**完全忽略了 Token 是否有效**，而是直接信任了请求体中 username 参数的值。攻击者可以利用此漏洞，通过拦截并篡改请求，在不知道对方重置令牌的情况下，任意重置其他用户（如 carlos）的密码，实现未授权账户接管。

4. 漏洞位置

漏洞端点：POST /forgot-password

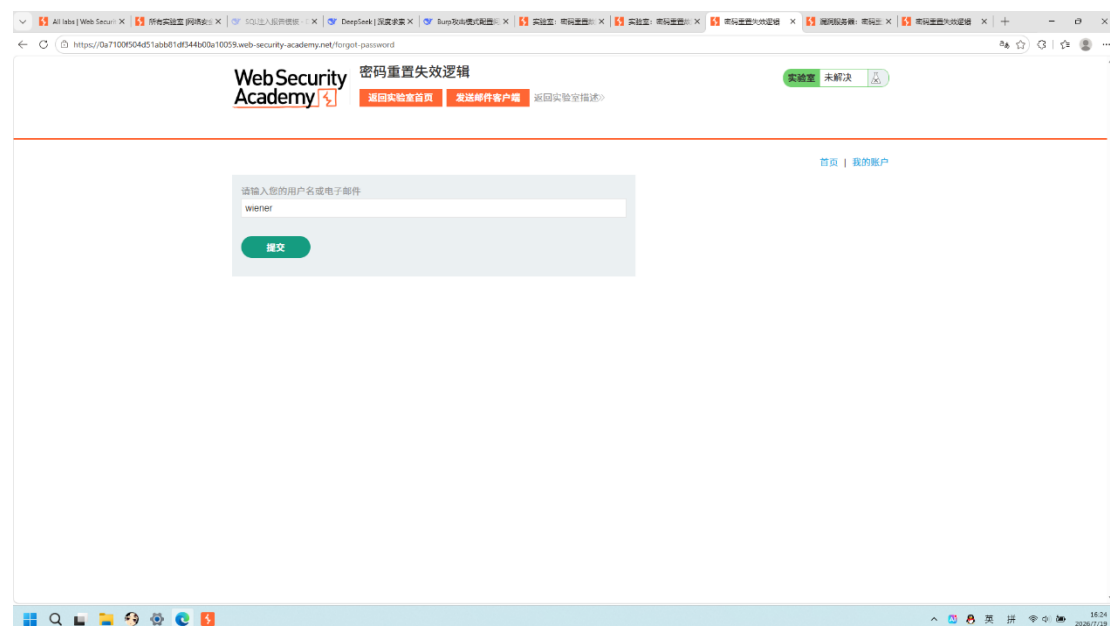
攻击向量：请求体参数 username 与 URL 中的 temp-forgot-password-token

5. 漏洞复现过程

第一步：正常触发密码重置流程

点击登录页面的“忘记密码”，输入测试账号 wiener，系统向邮箱发送密码重置邮件。

图 1：正常发起密码重置请求

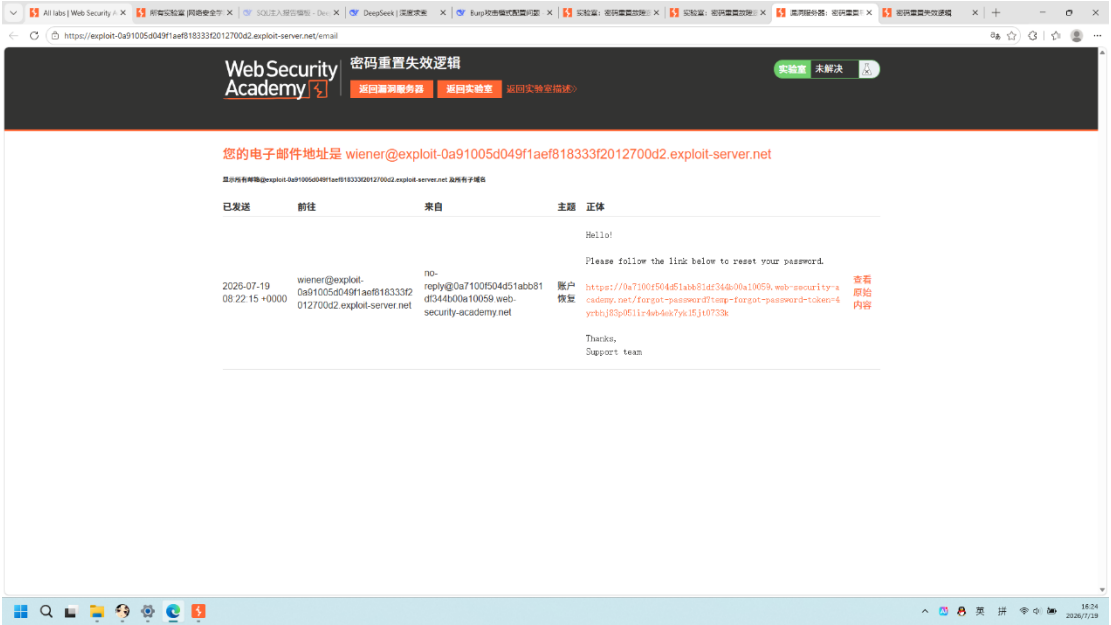


说明：正常触发重置流程，以获取重置请求的抓包数据。

第二步：查看重置邮件，获取数据特征

点击“邮件客户端（Email client）”查看收到的邮件，确认重置链接中包含了一个随机的 temp-forgot-password-token 参数。

图 2：邮件中包含密码重置 Token

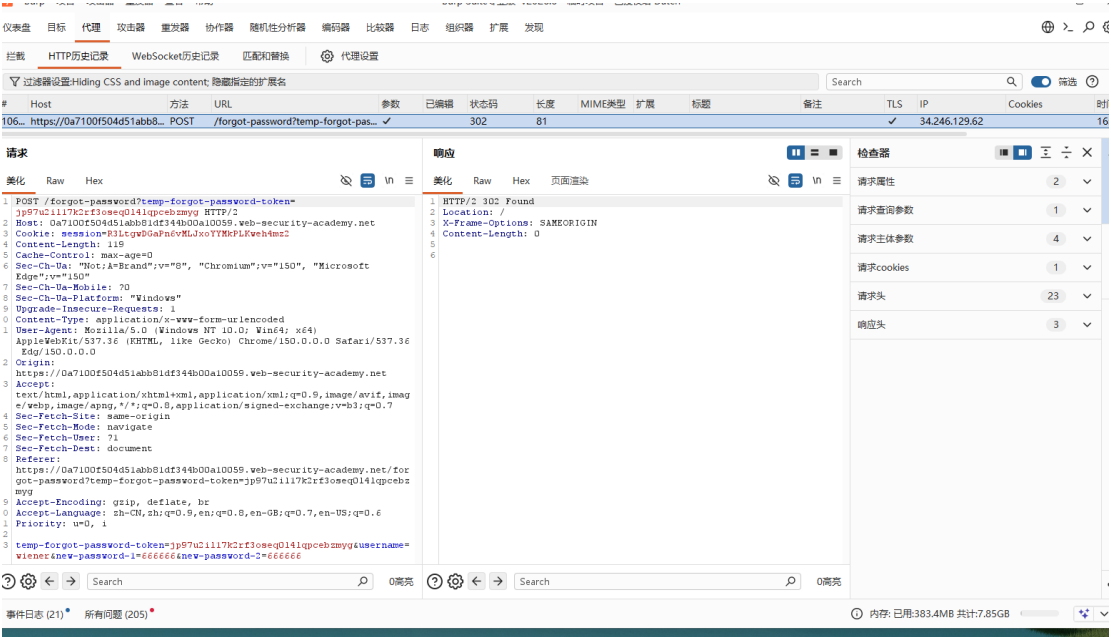


说明：链接包含了用于验证身份的 Token。

第三步：抓包分析密码重置请求

点击邮件中的重置链接，设置新密码。使用 Burp Suite 拦截并发送该 POST 请求到 Repeater。

图 3：Burp Repeater 截获修改密码请求



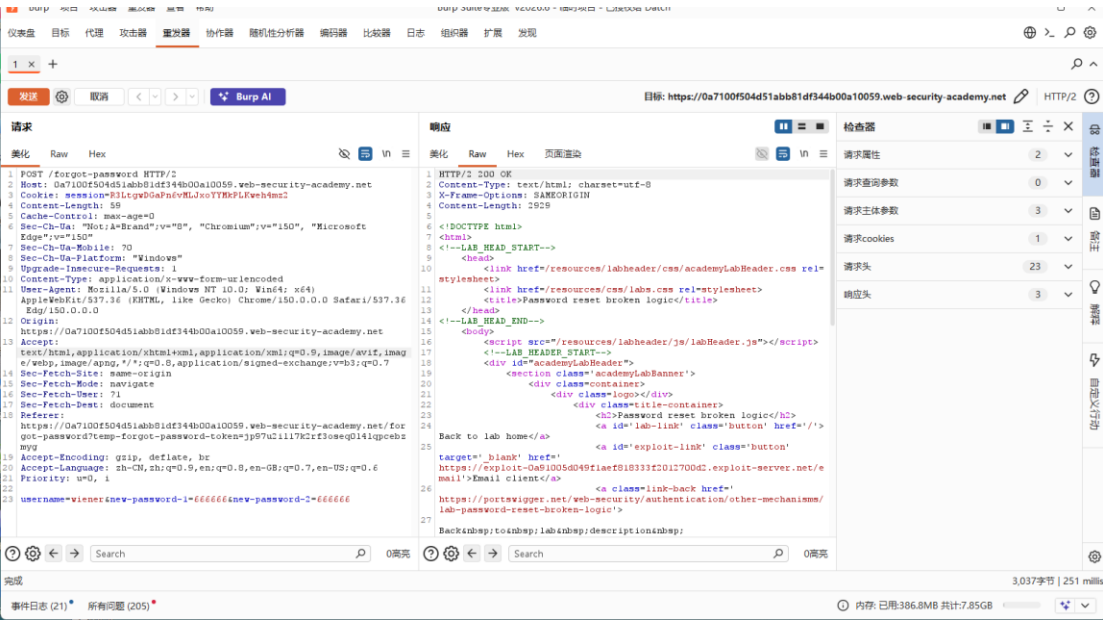
说明：观察确认请求体中包含了 username=wiener 和 temp-forgot-password-token 两

个关键参数。

第四步：验证 Token 是否有效（服务端漏洞确认）

在 Repeater 中，尝试将 URL 参数 temp-forgot-password-token 和请求体中的 temp-forgot-password-token 删除，发送请求。

图 4：绕过 Token 验证，逻辑确认

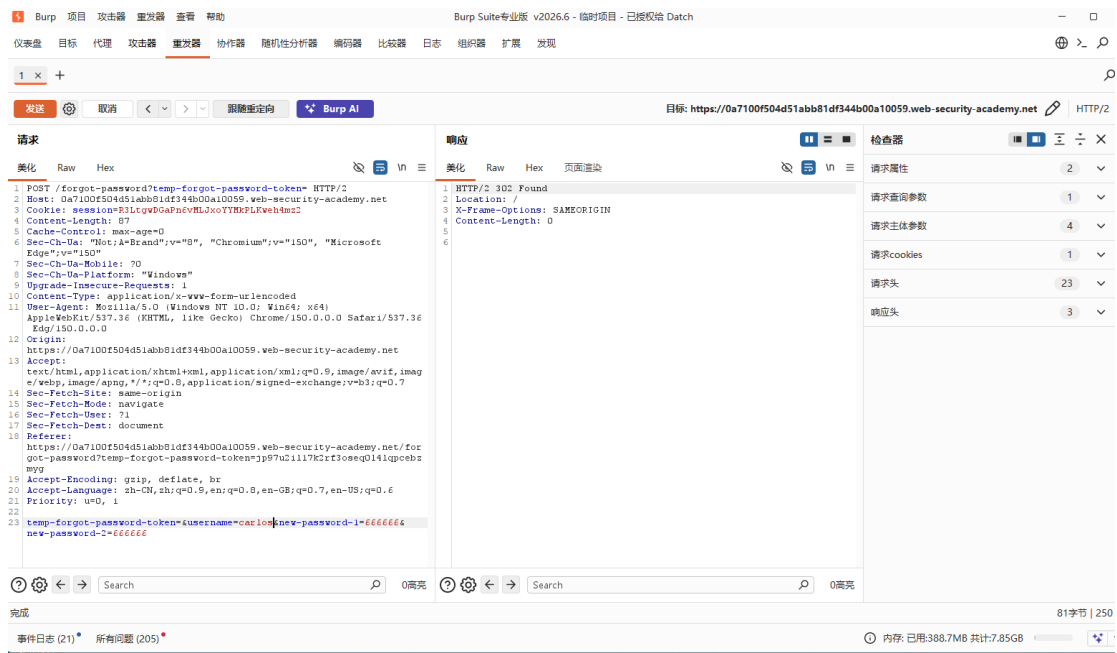


说明：删除 Token 后，服务器依然返回 200 并成功修改了密码。这确认了后端完全忽略了 Token，仅通过 Cookie 和 username 参数决定修改谁的密码！

第五步：横向越权修改目标用户密码

在 Repeater 中，将请求体里的 username=wiener 修改为目标用户 username=carlos，并重新设置一个新密码（如 123456）。

图 5：篡改用户名实现未授权重置



说明：携带自己的 Cookie，仅修改 username 参数，即可无需任何 Token 就把 carlos 的密码重置为攻击者指定的密码。

第六步：利用重置密码登录目标账户

使用刚刚修改的密码（如 123456）和用户名 carlos 登录系统，成功进入目标账户页面。

图 6：成功登录 Carlos 账户并完成实验



说明：利用逻辑漏洞成功接管目标账户。

6. 漏洞原理

这是一个典型的**服务端逻辑校验缺失**漏洞：

1. **正确的逻辑**：当用户点击邮件中的重置链接时，服务器应该**优先校验 URL 中的 temp-forgot-password-token 是否有效且属于当前用户**，然后才允许修改密码。
2. **错误的实现**：该网站后端在处理 POST 请求时，“**先执行修改，再校验**”或“**完全没校验**”。它仅根据请求体中的 username 参数，就将密码修改为攻击者指定的值。
3. **攻击结果**：攻击者只要登录自己的账号，抓包修改 username 参数，就能重置系统中任意用户的密码。

7. 漏洞影响

- **高危横向越权**：攻击者可利用此逻辑漏洞，直接重置所有已知用户名用户的密码。
- **大批量账号接管**：结合用户名枚举，攻击者可重置所有用户密码，导致整个系统被接管。

8. 修复建议

- ① **严格校验密码重置 Token**：在接收 /forgot-password 的 POST 请求时，后端必须从 URL 或 Body 中提取 temp-forgot-password-token，并在数据库查询该 Token 是否有效、是否过期、是否属于目标 username。只有 Token 校验通过，才允许执行修改。
- ② **Token 与用户强绑定**：生成的 Token 必须记录在服务端的数据库中，并作为用户标识的一部分。请求修改时，严禁仅凭客户端提交的 username 字段进行操作。
- ③ **一次性 Token**：确保重置 Token 被使用一次后立即销毁，防止重放攻击。

9. 工具

- **Burp Suite** (Proxy 拦截、Repeater 重放与修改请求)
- **PortSwigger Web Security Academy** (靶场平台)